

ORBITCLEAR TECHNOLOGIES LTD

Third-Party Risk Management Policy

Document Reference: POL-TP-001 | Version: 1.6 | Classification: Internal — Shareable under NDA

Field	Value
Owner	Vendor Risk Committee (chaired by COO)
Approver	Management Risk Committee
Approved	24 September 2024
Next review	September 2025
Supersedes	v1.5 (12 October 2023)
Regulatory references	DORA Arts 28–30 (ICT third-party risk) · EBA Guidelines on Outsourcing (EBA/GL/2019/02) · MAS Outsourcing Guidelines

Contents

§	Title
1	Purpose and Scope
2	Definitions and Tiering Model
3	Governance
4	Third-Party Lifecycle
5	Due-Diligence Requirements
6	Ongoing Monitoring and Assurance
7	Contractual Requirements
8	Exit and Offboarding
9	Review and Version History
Appendix A	Critical Sub-Processor Register (extract)
Appendix B	Due-Diligence Questionnaire (internal template)

1. Purpose and Scope

This Policy sets out how OrbitClear Technologies Ltd ("OrbitClear") identifies, assesses, and manages risks arising from third parties and sub-processors that support its services. The Policy applies across the whole third-party lifecycle — from sourcing through offboarding — and applies to all OrbitClear employees accountable for a third-party relationship.

2. Definitions and Tiering Model

Term	Definition
Third party	Any external organisation with which OrbitClear has a contractual or commercial relationship, including suppliers, sub-contractors and sub-processors.
Sub-processor	A third party engaged by OrbitClear that processes personal data or customer data on OrbitClear's behalf.
Critical / Tier 1	A sub-processor whose failure or compromise would materially affect OrbitClear's ability to deliver an Important Business Service, or would materially affect the confidentiality or availability of customer data.
Important / Tier 2	A sub-processor whose failure or compromise would cause significant but recoverable service degradation.
Standard / Tier 3	A third party with limited access to customer data or non-critical support role.

3. Governance

The Vendor Risk Committee ("VRC"), chaired by the COO, owns the third-party risk programme. The VRC meets monthly and reviews on-boarding decisions for Tier 1 and Tier 2 sub-processors, material changes to existing arrangements, and the outcomes of assurance activity. Executive escalation of material third-party risk is made to the Management Risk Committee.

4. Third-Party Lifecycle

Stage	Purpose	Key owners
Sourcing	Business need, risk-based pre-screening	Service owner, VRC
Due diligence	Risk assessment prior to engagement	Second-line Risk, CISO Office, DPO
Contracting	Flow-down of security, privacy, resilience terms	Legal, Procurement, CISO Office
Onboarding	Access provisioning, integration review	Service owner, Security Engineering
Monitoring	Ongoing assurance and performance management	Service owner, VRC, Second-line Risk
Offboarding	Return or destruction of data, access revocation	Service owner, Security Operations

5. Due-Diligence Requirements

Prior to engaging a sub-processor, due diligence shall be performed commensurate with the proposed tier. Evidence shall be held in the Vendor Register. Minimum due-diligence elements are as follows:

Tier	Minimum evidence
Tier 1 — Critical	Current SOC 2 Type 2 (or ISAE 3402 Type II, or ISO 27001 plus SOC 2 Type 2 where applicable); information security policy; business-continuity policy; financial stability report; data-protection assessment. Reports reviewed annually.
Tier 2 — Important	Current SOC 2 Type 1 or ISO 27001 certificate; completed security questionnaire; privacy assessment. Reviewed every two years.
Tier 3 — Standard	Completed short-form security questionnaire; cyber-insurance evidence where relevant.

All Tier 1 sub-processors shall be subject to an annual assurance cycle, comprising review of their latest independent assurance report, follow-up on management-response items, and an attestation by the second-line Risk function that the control environment remains acceptable.

6. Ongoing Monitoring and Assurance

- Independent assurance reports (SOC 2 Type 2 / ISAE 3402) are reviewed annually for Tier 1 sub-processors.
- Service-performance reviews are held quarterly with Tier 1 sub-processors, attended by the service owner and the VRC chair.
- Continuous monitoring of public cyber-reputation is performed through the BitSight platform for Tier 1 and Tier 2 sub-processors.
- Material changes to a sub-processor (e.g. change of control, change of data-processing location) require re-assessment.

7. Contractual Requirements

Contracts with Tier 1 and Tier 2 sub-processors shall include, as a minimum, the following clauses:

- Adherence to an information-security schedule equivalent to OrbitClear's.
- GDPR Article 28 processor terms, including sub-processor flow-down.
- Audit rights (remote, on-site, and pooled).
- Incident-notification obligations (within 24 hours of confirmation).
- Service-availability commitments and credits where relevant.
- Data-localisation and onward-transfer constraints consistent with OrbitClear's customer commitments.
- Exit assistance and return / destruction of data.

8. Exit and Offboarding

An Exit Plan shall be maintained for all Tier 1 sub-processors. The Plan shall include migration approach, alternative providers, data return or destruction, and assumed timeline. Offboarding of lower-tier third parties shall follow the standard leaver workflow, with confirmation of access revocation and data disposition.

9. Review and Version History

Version	Date	Author	Summary
1.6	24 Sep 2024	VRC Secretariat	Alignment to DORA ICT third-party terminology; clarification of §5 Tier 1 evidence requirements.

Version	Date	Author	Summary
1.5	12 Oct 2023	VRC Secretariat	Annual review; addition of BitSight continuous monitoring.
1.4	03 Jun 2022	VRC Secretariat	Initial issue under the unified policy framework.

Appendix A — Critical Sub-Processor Register (Extract)

The following is an extract of the Critical Sub-Processor Register maintained by the Vendor Risk Committee Secretariat. Tier 1 sub-processors as at the date of this Policy are:

#	Sub-processor	Service to OrbitClear	Tier	Location of processing	Most recent independent assurance reviewed
1	Amazon Web Services, Inc. (AWS Europe — Ireland and Germany)	Infrastructure hosting (compute, storage, database, KMS) for the OrbitClear Post-Trade Cloud	Tier 1	EEA (Ireland, Germany); limited US regions for specific services (see BC/DR Policy §6.4)	SOC 2 Type 2 (AWS), 1 Oct 2023 – 30 Sep 2024; ISO 27001. Reviewed 14 Dec 2024.
2	Okta, Inc.	Workforce identity provider for OrbitClear employees and contractors	Tier 1	EEA (Okta EU Cell) and US	SOC 2 Type 2, 1 Oct 2023 – 30 Sep 2024. Reviewed 22 Jan 2025.
3	Datadog EU S.à r.l.	Observability, metrics, logs, APM (EU region)	Tier 1	EEA (Datadog EU region, Frankfurt)	SOC 2 Type 2, 1 Nov 2023 – 31 Oct 2024. Reviewed 18 Feb 2025.

End of Appendix A extract. The Critical Sub-Processor Register is maintained in the VRC's ServiceNow Vendor Risk module and updated on material change. Changes are notified to affected customers per contractual terms.

Appendix B — Due-Diligence Questionnaire (Template — Summary)

Tier 1 due-diligence questionnaire template, summarised here for reference. The full template is maintained in ServiceNow.

- Corporate — incorporation, ownership, financial stability, regulatory status.
- Security — ISO 27001 / SOC 2 status; encryption; access management.
- Privacy — GDPR Article 28 readiness; sub-processor transparency.
- Resilience — BCP/DR plans; historical incident record; RTO/RPO.
- Exit — ability to return or destroy data; migration approach.
- Financial — audited accounts or equivalent.